

IPOG Instituto de Pós-Graduação e Graduação
Projeto Integrador Cibersegurança

RELATÓRIO EXECUTIVO

Avaliação de Segurança da Plataforma crAPI

O que testamos, o que encontramos e o que precisa ser feito

Professor orientador: Rodrigo Muniz
Aluno: Arlindo
Maio / 2026 Goiânia, GO

1. Resumo Executivo

Durante seis semanas, realizamos uma avaliação completa de segurança da plataforma crAPI uma aplicação de gerenciamento de veículos. O objetivo foi simular o que um invasor real faria, identificar as brechas existentes e propor como corrigi-las.

O resultado foi direto: encontramos seis falhas de segurança sérias. Todas foram comprovadas, não são hipóteses. Em uma situação real, essas brechas permitiriam que qualquer pessoa com acesso à internet vazasse dados de clientes, derrubasse o serviço ou acessasse os bancos de dados da empresa sem precisar de nenhuma habilidade especial.

O que isso significa em linguagem simples

Imagine que a porta traseira da sua loja ficou destrancada. Um funcionário mal-intencionado ou qualquer pessoa que descobrisse isso poderia entrar, pegar o que quisesse e sair sem deixar rastros e a câmera de segurança não registraria nada. É exatamente o cenário que encontramos nesta avaliação. A boa notícia: identificamos o problema, instalamos câmeras melhores e agora sabemos exatamente como trancar essa porta.

O que foi testado	O que foi encontrado
Plataforma de gerenciamento de veículos com sistema de login, perfis de usuários, mecânicos e compras	6 falhas de segurança todas comprovadas com evidências reais
Cenário: um atacante externo com acesso básico à plataforma	O atacante conseguiu acessar dados de outros clientes, derrubar o serviço e obter senhas do banco de dados

O que foi testado	O que foi encontrado
Ferramentas usadas: as mesmas disponíveis gratuitamente na internet para qualquer pessoa	Nenhuma brecha exigiu conhecimento avançado para ser explorada

2. Matriz de Risco

A matriz abaixo classifica cada falha encontrada pela facilidade com que pode ser explorada versus o tamanho do problema que causaria. Quanto mais à direita e acima, mais urgente é a correção.

Facilidade de exploração → Impacto ↓	Qualquer pessoa	Com algum conhecimento	Especialista	Muito difícil
Empresa fecha / LGPD	Senhas do banco expostas Log4Shell (RCE)			
Impacto grave	Dados de clientes vazados Serviço fora do ar	Acesso a sistemas internos (SSRF)		
Impacto moderado	Fraude com cupons de desconto			
Impacto baixo				

Figura: Matriz de Risco quanto mais vermelho, mais urgente a correção

	Vermelho Risco crítico. Ação imediata. Pode resultar em multa, processo judicial ou fechamento de contratos.
	Amarelo Risco alto. Correção prioritária. Pode causar perda financeira ou impacto operacional.
	Verde Risco aceitável. Monitorar e corrigir no ciclo normal de desenvolvimento.

3. Impacto no Negócio

Esta seção traduz cada falha técnica encontrada para o que ela significa na prática para a empresa, seus clientes e sua reputação.

Falha 1 Dados de clientes expostos (MAIS URGENTE)

Descobrimos que qualquer usuário cadastrado na plataforma pode ver a localização GPS, o nome completo e o e-mail de outros clientes sem precisar hackear nada, apenas fazendo uma requisição normal ao sistema. Em produção, isso equivale a vaziar o cadastro completo dos seus clientes para qualquer concorrente ou pessoa mal-intencionada que criar uma conta. Sob a Lei Geral de Proteção de Dados (LGPD), esse tipo de vazamento pode gerar multas de até 2% do faturamento bruto anual, limitadas a R\$ 50 milhões por infração, além do dano reputacional irreparável com clientes.

Falha 2 Senhas do banco de dados expostas publicamente

Um arquivo com as senhas dos bancos de dados da aplicação (PostgreSQL e MongoDB) estava acessível para qualquer pessoa que soubesse onde procurar sem precisar de login. Com essas credenciais, um atacante teria acesso total a todos os dados armazenados: cadastro de clientes, histórico de transações, dados de veículos e qualquer informação sensível. É como deixar a chave do cofre colada na porta da frente.

Falha 3 Serviço pode ser derrubado por qualquer usuário

Confirmamos que um único usuário comum, sem nenhum conhecimento técnico especial, consegue tornar o serviço completamente indisponível em segundos. Em ambiente de produção, isso representa interrupção de operações, perda de vendas durante o período de queda e possível violação de acordos de nível de serviço (SLA) com clientes. O sistema não tinha nenhuma proteção contra esse tipo de abuso.

Falha 4 Servidor pode ser usado como ponte para ataques internos

Identificamos uma falha que permite que um atacante use o próprio servidor da aplicação como intermediário para acessar outros sistemas da infraestrutura interna sem nunca ter acesso direto a eles. Em ambientes de nuvem (AWS, Azure, GCP), essa técnica é frequentemente usada para roubar credenciais de acesso à infraestrutura inteira. O impacto potencial vai muito além da aplicação pode comprometer toda a operação de TI da empresa.

Falha 5 Fraude financeira via cupons de desconto

Utilizando uma técnica de injeção de dados, conseguimos obter cupons de desconto válidos (R\$ 75,00) sem conhecer nenhum código real o sistema simplesmente entregou o desconto. Em escala, isso pode representar prejuízo financeiro significativo caso a vulnerabilidade seja descoberta e explorada por usuários mal-intencionados de forma automatizada.

4. Plano de Mitigação

A boa notícia é que todas as correções necessárias são tecnicamente viáveis, de baixo custo e algumas já foram aplicadas durante este projeto utilizando ferramentas gratuitas. Abaixo está o plano estruturado por ordem de prioridade.

Prioridade 1 Faça agora (esta semana)

O que corrigir	Por que é urgente	O que acontece se não corrigir
Remover as senhas do banco de dados do local público e trocá-las imediatamente	Qualquer pessoa pode acessar todos os dados da empresa agora	Vazamento total de dados LGPD multa de até R\$ 50 milhões
Impedir que usuários vejam dados de outros clientes	Viola a privacidade de todos os usuários da plataforma	Processo judicial, perda de confiança, notificação obrigatória à ANPD

Prioridade 2 Faça em até 30 dias

O que corrigir	Benefício esperado	Custo estimado
Instalar proteção contra sobrecarga de requisições (rate-limit)	Serviço resistente a tentativas de derrubada	Já implementado neste projeto custo zero
Restringir o servidor a não acessar endereços externos não autorizados	Elimina risco de uso do servidor como porta de entrada para a infraestrutura	2 horas de desenvolvimento
Adicionar validação nos campos de entrada de dados	Elimina fraude com cupons e outras manipulações de dados	1–2 dias de desenvolvimento

Prioridade 3 Faça em até 90 dias

O que implantar	Benefício	Custo estimado
Firewall de aplicação (WAF) com regras automáticas de proteção	Bloqueia automaticamente centenas de tipos de ataque conhecidos	Ferramenta gratuita 2 dias de configuração
Testes automáticos de segurança a cada nova versão do sistema	Garante que novas funcionalidades não introduzam as mesmas falhas	1 semana de configuração inicial
Atualização da biblioteca de registro de eventos (Log4j)	Elimina vulnerabilidade crítica com nota máxima de risco (10/10)	Menos de 1 hora

O que já foi corrigido neste projeto

Durante a avaliação, implementamos imediatamente três proteções: (1) um servidor intermediário com cabeçalhos de segurança que impedem ataques comuns de navegador; (2) limite de requisições por IP que bloqueia tentativas de derrubar o serviço, retornando erro 429 ao invés de deixar o sistema cair; (3) bloqueio de acesso público ao arquivo de senhas, que agora retorna erro 403 ao invés de exibir as credenciais. Custo de todas essas melhorias: zero, foram implementadas com ferramentas open source.

5. Conclusão e Recomendação Final

A avaliação revelou que a plataforma, em seu estado original, apresentava riscos que qualquer usuário poderia explorar sem necessidade de conhecimento técnico avançado. As falhas encontradas são conhecidas e documentadas internacionalmente, o que significa que atacantes também conhecem e buscam ativamente por elas.

Nossa recomendação

Trate as correções de Prioridade 1 como emergência elas devem ser resolvidas ainda esta semana, antes de qualquer novo acesso de usuários reais ao sistema. As demais correções devem ser incluídas no roadmap imediato da equipe de tecnologia. O investimento total estimado é de uma a duas semanas de trabalho de desenvolvimento, sem custo de licenciamento. O custo de não agir uma única notificação de vazamento de dados à ANPD, multa da LGPD ou manchete negativa na imprensa supera em muito o esforço necessário para as correções.

Cenário sem correção	Cenário com correção
Dados de todos os clientes expostos a qualquer usuário	Acesso restrito cada usuário vê apenas seus próprios dados
Senhas do banco acessíveis publicamente 24h por dia	Credenciais protegidas arquivo bloqueado por firewall
Serviço pode ser derrubado por qualquer usuário a qualquer momento	Proteção ativa tentativas de sobrecarga são bloqueadas automaticamente
Risco de multa LGPD de até R\$ 50 milhões por incidente	Conformidade com boas práticas de privacidade de dados